۱۴۰۵/۰۷/۲۵

گزارش ۱

۱- ایرادات زیر در جدول لاگ های امنیتی رفع شوند:

* ستون شناسه کاربر خالی است یا برای برخی رکورد ها صرفا یک عدد مانند ۱ ثبت شده است.
* شناسه کاربری همان نام کاربری است؟
* برای تمامی ستون ها نیاز به فیلد جستجو جداگانه داریم. برای مثال ستون نوع رویداد فاقد فیلد جستجو است.
* تمامی ستون ها نیازمند قابلیت مرتب سازی جداگانه هستند(مرتب سازی نباید صرفا در UI رخ دهد)
* فیلتر آی پی به درستی کار نمیکند. لطفا بررسی کنید.

۲- نقش جدید ایجاد شده اما در نام کاربری مشخص نیست کدام کاربر این نقش را ایجاد کرده است:

شناسه	شناسه کاربر	آدرس IP	نوع رویداد	توضیحات	زمان
13976	1	89.41.240.221	USER_DATA_CHANGE	ایجاد نقش افتا	15:46 1405/07/25

۳- در زمان ایجاد کاربر خطای زیر دریافت میشود:

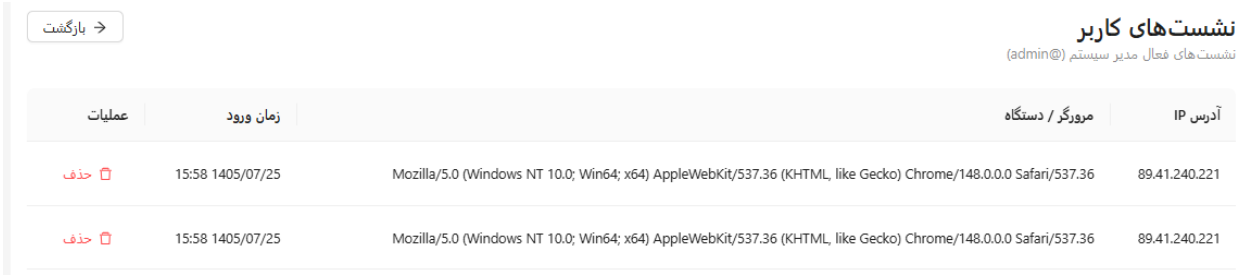


۴- پس از تغییر دسترسی های نقش باید مشخص شود چه دسترسی هایی به این نقش اضافه شده و چه دسترسی هایی گرفته شده:

شناسه	شناسه کاربر	آدرس IP	نوع رویداد	توضیحات	زمان
13977	1	89.41.240.221	USER_DATA_CHANGE	بروزرسانی نقش افتا	15:56 1405/07/25

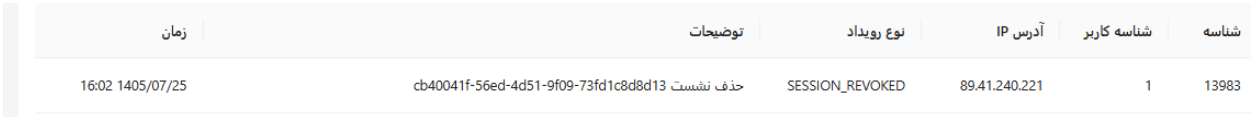
این موارد باید در بخش توضیحات اضافه شوند.

۵- در صفحه نشست های کاربران برای تمامی ستون ها قابلیت جستجو و مرتب سازی قرار دهید:



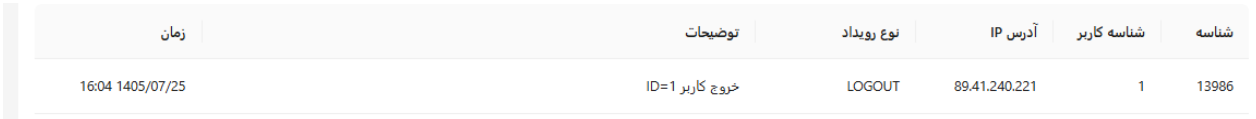
۶- پس از خروج کاربر به دلیل رسیدن تعداد نشست های فعال کاربر به حداکثر تعداد مجاز، لاگ امنیتی مربوط به این رخداد ثبت نشد.

۷- پس از حذف نشست لاگ زیر ایجاد میشود:



نام کاربری ثبت شود
آی دی نشست حذف شده نیازی نیست ثبت شود
چه کاربری نشست چه کاربر دیگری را پایان داده؟
همچنین بعد از حذف نشست کاربر مربوطه به درستی از سامانه خارج شد اما لاگ خروج او از سامانه و دلیل خروج ثبت نمیشود. حذف نشست رویدادی جدا از خروج از سامانه است.
هر جا هر خروجی رخ داد باید لاگ مربوطه با دلیل دقیق و مشخص خروج ثبت شود.

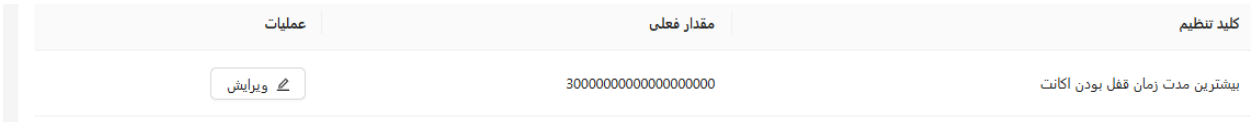
۸- لاگ زیر ویرایش شود.
Id= 1 معنا ندارد و حذف شود
نام کاربری اضافه شود:



۹- مقادیر ورودی تنظیمات اعتبار سنجی شود. برای مثال این مورد فقط باید پذیرای دو مقدار True یا False باشد:

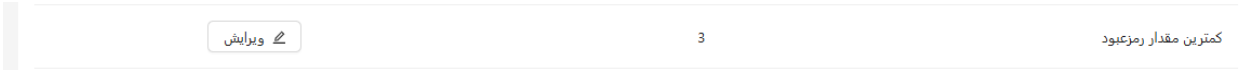


تنظیمات با مقادیر عددی نیز باید تنها پذیرنده مقادیر محدود شده باشند:

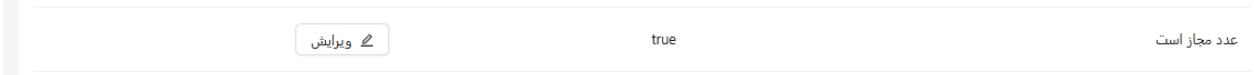


برای مثال همین مورد را بررسی کنید
همچنین بفرمایید اصلا این تنظیم چیست؟
چه کاری انجام میدهد؟

۱۰-مقدار تنظیم زیر باید عددی بین ۸ تا ۲۵ باشد:

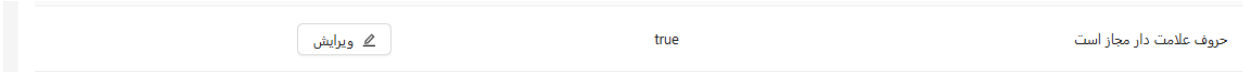


۱۱-لطفا کمی تنظیمات ایجاد شده را مرتب کنید



این مورد مربوط به رمز عبور است
حداقل مینوشتید الزام وجود عدد در رمز عبور!!

۱۲-استفاده از اصطلاح مجاز است در ساختار رمز عبور اشتباه است:



الان این مورد به این معناست که اگر این تنظیم روشن باشد کاربر میتواند از حروف استفاده کند و میتواند نکند.
اگر خاموش باشد به این معناست که نباید استفاده کند.
ساختار صحیح به این شکل است: الزام استفاده از حروف خاص در رمز عبور.

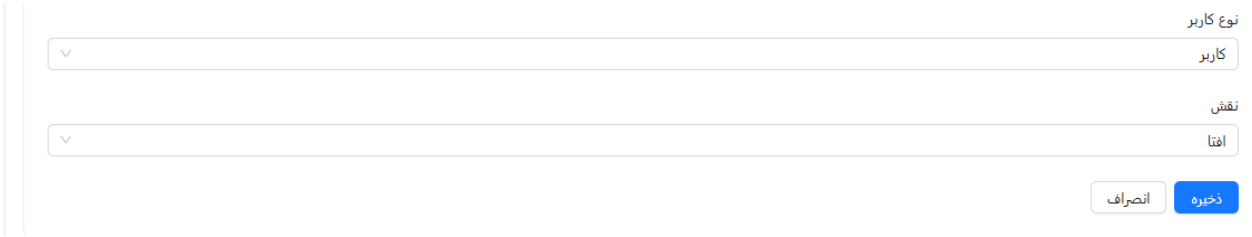
۱۳-لطفا پس از رخدادن هر گونه تغییری در تنظیمات امنیتی، تمامی نشست های فعال پاک شوند، برای تمامی نشست های حذف شده لاگ امنیتی ثبت شود.
پس از هر تغییر امنیتی، تمامی کاربران ملزم به ایجاد نشست مجدد هستند.

۱۴-در زمان ایجاد کاربر خطای زیر دریافت میشود:

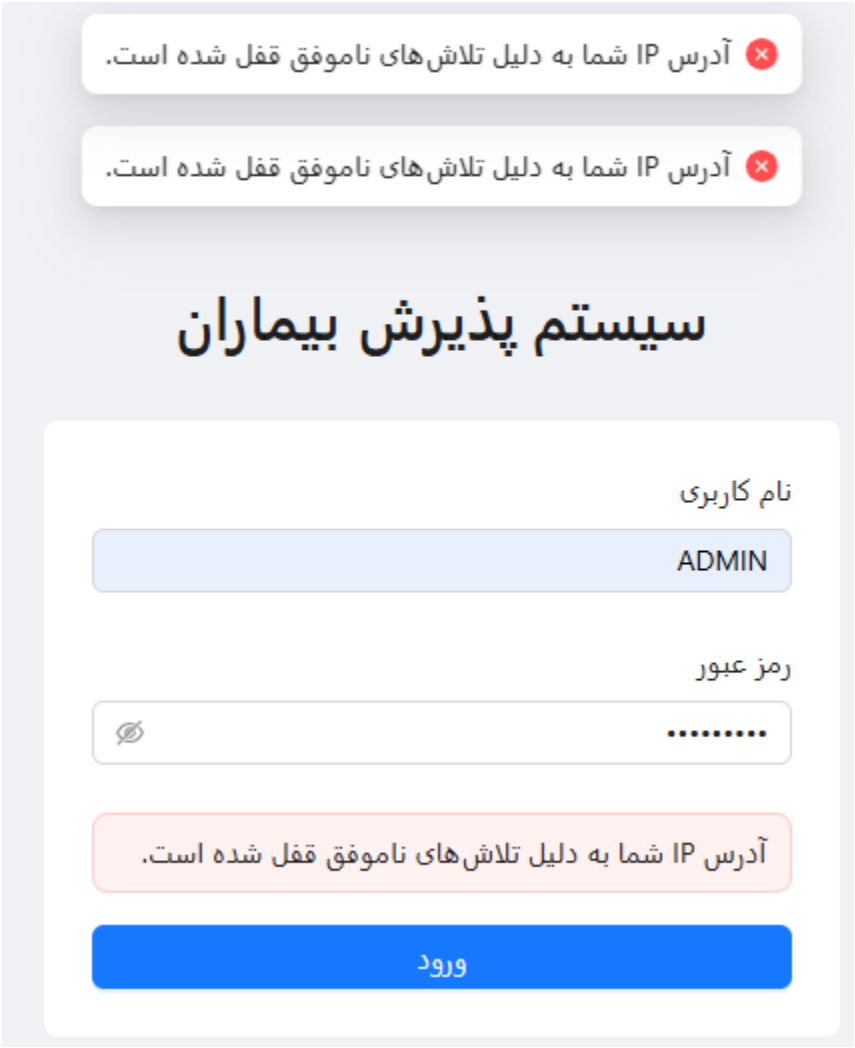


دلیل چیست؟ این مشکل برطرف شود.

تفاوت کاربرد این دو مورد در ایجاد کاربر را هم توضیح دهید:



۱۵-در صورتی که کاربر به دلیل احراز هویت های ناموفق قفل شد، باید خود کاربری هم قفل شود.:



در این مورد که کاربر با نام کاربری Admin وجود دارد باید کاربری Admin به مدت زمان مشخص شده در تنظیمات قفل شود.
در صورتی که نام کاربری وجود نداشت Ip قفل میشود.

۱۶- تنظیم امنیتی حداکثر حجم جداول لاگ کجاست ؟ در Task1 به شما علام شده بوده است. ایا اصلا پیاده سازی این تسک انجام شده است؟؟؟

۱۷- در لاگ های امنیتی مربوط به تغییر تنظیمات باید مقدار قبل و بعد هر دو مشخص باشد

1405/07/25 16:15	تغییر تنظیم MaximumNumberOfFailedLogin به 2	SECURITY_SETTING_CHANGE	89.41.240.221	1	13993
1405/07/25 16:15	تغییر تنظیم MaximumTimeOfUserIpBeingLocked به 1	SECURITY_SETTING_CHANGE	89.41.240.221	1	13992

شما فقط مقدار جدید را ثبت میکنید.

۱۸-در فرایند زیر:

شناسه	شناسه کاربر	آدرس IP	نوع رویداد	توضیحات	زمان
13996	1	89.41.240.221	LOGIN_SUCCESS	ورود موفق — admin	1405/07/25 16:19
13995	1	89.41.240.221	LOGIN_FAILED	رمز اشتباه — admin	1405/07/25 16:16
13994	1	89.41.240.221	LOGIN_FAILED	رمز اشتباه — admin	1405/07/25 16:16

کاربر به دلیل احراز هویت اشتباه یک مرتبه قفل شده است اما لاگ قفل شدگی کاربر ثبت نشده.
همچنین لاگ ورود نا موفق به دلیل قفل بودن کاربر هم ثبت نمیشود.

۱۹-سامانه علاوه بر وجود احراز هویت معمولی، نیازمند حداقل یک روش احراز هویت دو فاکتوری مانند پیامک، ایمیل و یا ابزاری مانند Google authenticator است.
یکی از این موارد حداقل پیاده سازی شود و فعال و غیرفعال بودن آن از طریق تنظیمات امنیتی قابل تنظیم باشد.

۲۰- نیاز است قابلیتی وجود داشته باشد تا طبق آن سامانه عدم فعالیت کاربر را تشخیص داده و اگر بیش از مدت زمان مشخص تنظیم شده کاربر فعالیتی نداشت و هیچ End point یا API صدا نزده بود، نشست او پاک شده، کاربر خارج شود و مجدد ایجاد نشست کند. تمامی لاگ های امنیتی مربوط به این رویداد هم باید ثبت شود.

۲۱- لاگ به روز رسانی کاربر به صورت دقیق ثبت شود. کدام فیلد کاربر تغییر کرده است؟؟؟

شناسه	شناسه کاربر	آدرس IP	نوع رویداد	توضیحات	زمان
14004	1	89.41.240.221	USER_DATA_CHANGE	به‌روزرسانی کاربر admin	16:27 1405/07/25

۲۲- نیازمند صفحه ای به نام لاگ های سیستمی هستیم.
سامانه باید تمامی API call ها توسط تمامی کاربران را ثبت و در یک جدول ذخیره کند و دقیقا مانند لاگ های امنیتی آن را با سختار دارای فیلتر و مرتب سازی به کاربران دارای دسترسی نمایش دهد.
ستون های مورد نیاز:
نام کاربری
تاریخ و زمان
نام کنترلر یا API
مقادیر ورودی

مقادیر خروجی
IP
خطا(در صورت وجود هر گونه خطا به همراه متن خطا)

۲۳- تنظیمات اپلود در سامانه دیده میشود اما خود فرایند آپلود بنظر وجود ندارد. فرایند آپلود در چه بخشی از نرم افزار رخ میدهد؟؟؟

۲۴- وظیفه این تنظیم چیست؟؟

آخرین رویداد ثبت شده 6 ویرایش